

DESTINY

SECURITY ASSESSMENT
WEB / API / AI

ПРИМЕР ОТЧЁТА О ПЕНТЕСТЕ

Сводка рисков. Доказательства. Исправления.
Критерии повторной проверки.

Демонстрационный документ. Все данные вымышлены.

02 Сводка и объём проверки

03-04 DEMO-01 / Доступ к чужим документам

05-06 DEMO-02 / Права AI-агента

07 Ретест и передача команде

destiny.by

security@destiny.by

01 / РИСКИ И ГРАНИЦЫ

Сводка и объём проверки

Сводка переводит технические наблюдения в последствия для продукта и порядок действий. В этих примерах нарушаются две разные границы доверия.

Web / API · DEMO-01

Данные одного клиента доступны другому

Обычная учётная запись позволяет получить чужой документ. Первая задача - закрыть доступ на уровне объекта и проверить похожие операции в API.

AI / RAG · DEMO-02

Документ управляет действием агента

Внешняя инструкция приводит к запросу вне прав пользователя. Первая задача - обеспечить независимую проверку разрешений на стороне инструмента.

Приоритет определяется контекстом. Учитываются доступность сценария для атакующего, требуемые права, состав данных, масштаб затронутых объектов и существующие ограничения.

Объём и ограничения

Отчёт описывает проверенные системы, роли, операции и ограничения. По нему должно быть понятно, на какие области распространяются выводы.

Область	Что рассматривается в образце	Что фиксируется в проекте
Web / API	Доступ к документам между организациями.	Приложения, версии, роли, операции и тестовые учётные записи.
AI / RAG	Влияние внешнего документа на вызов инструмента.	Модель, источники знаний, инструменты и права пользователя.
Повторная проверка	Критерии подтверждения исправлений.	Версия после исправления, повторённые сценарии и итоговый статус.
За пределами образца	Сеть, облачная инфраструктура, социальная инженерия и нагрузка.	Исключения, недоступные компоненты и ограничения методов.

Фактическое покрытие в рабочем отчёте отделяется от согласованного плана: недоступная функция или непроверенная роль остаются отмеченными как ограничения.

02 / DEMO-01 · WEB / API

Доступ к чужим документам

Пользователь одной организации получает документ другой. Приложение проверяет вход в систему, но пропускает проверку права на конкретный объект.

Условная система	Исходный доступ	Нарушенная граница
app.example	**Обычная учётная запись**	**Изоляция организаций**

Влияние на бизнес

Ошибка создаёт путь к клиентским документам за пределами разрешений. Возможный ущерб зависит от чувствительности документов, доступных операций и количества объектов. Возможность чтения сама по себе не доказывает возможность изменения или удаления - эти действия проверяются отдельно.

Путь через границу доверия

Учётная запись A → **API документов** → **Документ организации B**

Необходимые условия

- Две организации используют одно приложение.
- Обычный пользователь может обращаться к API документов.
- Документы должны быть разделены по организациям.

Что подтверждает нарушение

- Целевой документ принадлежит организации B.
- У пользователя A нет разрешения на него.
- Ответ содержит данные документа, а не только иной код состояния.

Запись доказательства

Пользователь	DEMO_USER_A · роль «Чтение»
Организация	DEMO_TENANT_A
Целевой объект	DEMO_DOCUMENT_B
Владелец объекта	DEMO_TENANT_B

Ожидается. Сервер отклоняет обращение к чужому документу и не возвращает его содержимое.

Наблюдение в сценарии. Ответ содержит документ организации B при использовании учётной записи организации A.

В рабочем отчёте к записи прилагаются запрос и ответ с безопасными идентификаторами, версия системы, время проверки и условия повторения.

DEMO-01 / WEB · API

Исправление и проверка результата

Логика воспроизведения

01 Подготовить согласованные тестовые организации и документы с заранее известными владельцами.

02 Проверить штатное чтение своего документа и отсутствие разрешения на чужой.

03 Обратиться к тестовому чужому объекту с правами пользователя A.

04 Сопоставить фактические данные ответа с владельцем объекта и сохранить доказательство.

План исправления

Проверять права на сервере при каждом обращении

Решение о доступе должно учитывать пользователя, действие, объект и организацию.

Брать контекст доступа из доверенного источника

Переданное клиентом значение организации не должно само по себе давать доступ.

Закрыть аналогичные пути

Проверить чтение, выгрузку и другие согласованные операции с тем же типом объектов.

Закрепить границу регрессионной проверкой

Добавить сценарии для разных ролей и организаций, включая отказ при отсутствии разрешения.

Критерии ретеста

- Чужой документ не возвращается через согласованные точки доступа.
- Разрешённое чтение своего документа продолжает работать.
- Граница сохраняется для согласованных ролей и связанных операций.
- Исправление проверено на указанной версии приложения, результат связан с DEMO-01.

03 / DEMO-02 · AI / RAG

Подмена инструкций и права агента

Документ из базы знаний меняет поведение агента. Инструмент принимает сформированный агентом запрос без независимой проверки прав пользователя.

Условная система	Исходный доступ	Нарушенная граница
assistant.example	**Чтение данных своей команды**	**Источник знаний → действие**

Влияние на бизнес

Недоверенный источник может стать причиной действия вне разрешений: запроса чужих данных или изменения объекта. В образце зафиксировано принятие неразрешённого запроса тестовым инструментом. Фактический экспорт и передача данных не моделируются.

Путь через границу доверия

Внешний RAG-документ → **AI-агент** → **Инструмент экспорта**

Пользователь просит сводку по своей команде. Агент читает внешний документ через RAG и имеет доступ к инструменту экспорта. Документ должен оставаться источником данных; его содержимое не даёт пользователю дополнительных прав.

Запись доказательства

Пользователь	DEMO_READER_A · чтение своей команды
Источник знаний	DEMO_RAG_DOCUMENT · внешний документ
Запрошенное действие	Экспорт данных другой команды
Решение инструмента	Запрос принят без проверки роли

Ожидается. Инструмент проверяет пользователя, действие и область данных до выполнения. Запрос вне прав отклоняется.

Наблюдение в сценарии. Внешняя инструкция влияет на вызов. Проверка разрешения на стороне инструмента отсутствует.

В рабочем отчёте связываются версия источника, контекст роли, трасса вызова, параметры и итог выполнения. Намерение модели, принятый вызов и совершённая операция фиксируются отдельно.

DEMO-02 / AI · RAG

Исправление и проверка результата

Условия воспроизведения

01 Зафиксировать модель, настройки агента, источники RAG и доступные операции.

02 Выполнить штатную задачу с тестовыми данными и ограниченной ролью.

03 Проверить согласованный сценарий влияния внешнего документа на вызов инструмента.

04 Сопоставить запрошенное действие с правами пользователя и решением инструмента.

Для недетерминированного поведения в отчёте нужны условия и наблюдения отдельных прогонов, а также различия между ними.

План исправления

Проверять разрешения вне модели

На стороне инструмента сопоставлять пользователя, операцию и ресурс. Отсутствие разрешения должно останавливать выполнение.

Ограничить права агента

Оставить сервисной учётной записи только необходимые операции и области данных.

Контролировать параметры и последствия

Проверять область действия запроса до выполнения; отдельно согласовать подтверждение чувствительных операций.

Отделить источники знаний от управляющих инструкций

Недоверенный контент не должен менять правила доступа. Эта граница должна сохраняться независимо от ответа модели.

Критерии ретеста

- Инструмент отклоняет вызов вне прав, даже если агент сформировал его.
- Нет побочного действия до проверки разрешения.
- Штатная задача выполняется в пределах роли пользователя.
- Согласованные вариации источников, ролей и ресурсов не расширяют доступ.
- В отчёте указаны версии модели, приложения и настроек, на которых повторялись сценарии.

04 / РЕЗУЛЬТАТ РАБОТЫ

Ретест и передача команде

Ретест отвечает на конкретный вопрос: изменился ли результат ранее подтверждённого сценария. Для каждой находки фиксируются версия системы, проверенные условия и один из статусов.

Исправлено

Сценарий больше не воспроизводится, согласованные связанные проверки пройдены. Указаны условия и границы вывода.

Исправлено частично

Часть пути закрыта, но остаётся вариант воспроизведения или непокрытая часть согласованного исправления.

Воспроизводится

После изменений нарушение сохраняется. Приведено актуальное доказательство на новой версии.

Не удалось проверить

Нет необходимого доступа, компонента или условия. Указана причина; такой статус не означает исправление.

Что получает команда

01 / Сводка для принятия решений

Основные риски, приоритет исправлений и ограничения проверки. Основа для решения о выпуске, сроках и распределении ресурсов.

02 / Находки для разработки

Идентификатор, затронутая область, условия, доказательства, влияние, рекомендации и критерии приёмки исправления.

03 / Карта покрытия

Проверенные системы, роли и сценарии. Недоступные участки и исключения видны отдельно от выполненных работ.

04 / Обновление после ретеста

Связь каждого повторного наблюдения с исходной находкой, версией исправления и итоговым статусом.

Обсудить проверку

Опишите продукт и критичные операции. Определим объём проверки и результат, который нужен вашей команде.

security@destiny.by / LinkedIn / destiny.by